Tài liệu Đặc tả Yêu cầu Phần mềm (SRS)

Hệ thống Thương mại Điện tử — Fruitables

Phiên bản: 2.0 **Ngày:** 20/03/2026 **Nền tảng:** ASP.NET Core MVC (.NET 8), Entity Framework Core, SQL Server

---

1. Giới thiệu

1.1 Mục đích

Tài liệu này mô tả các yêu cầu phần mềm của hệ thống thương mại điện tử Fruitables. Tài liệu phục vụ cho nhóm phát triển, tester và các bên liên quan nhằm thống nhất phạm vi và hành vi kỳ vọng của hệ thống.

1.2 Phạm vi dự án

Fruitables là website bán trái cây và rau củ trực tuyến, bao gồm:

Trong phạm vi:

- Khu vực Public: duyệt sản phẩm, mua hàng, quản lý tài khoản cá nhân
- Khu vực Admin: quản lý kho hàng, đơn hàng, người dùng, doanh thu, cấu hình hệ thống

Ngoài phạm vi:

- Ứng dụng di động (mobile app)
- Tích hợp hệ thống kế toán/ERP bên ngoài
- Quản lý vận chuyển bên thứ ba (chỉ tính phí ship nội bộ)

1.3 Đối tượng sử dụng

Vai trò	Mô tả
Guest (Khách vãng lai)	Duyệt sản phẩm, thêm vào giỏ hàng, đặt hàng không cần đăng nhập, tra cứu đơn hàng bằng SĐT
Customer (Khách hàng)	Đã đăng ký tài khoản, quản lý profile, địa chỉ, lịch sử đơn hàng, viết đánh giá
Admin	Quản lý sản phẩm, danh mục, đơn hàng, người dùng, mã giảm giá, nội dung, thống kê
SuperAdmin	Toàn quyền Admin, thêm quyền khóa/mở khóa tài khoản và quản lý RBAC

---

2. Yêu cầu tổng thể

2.1 Yêu cầu chức năng

Module	Mô tả
F1 — Xác thực người dùng	Đăng ký, đăng nhập (email/mật khẩu + Google OAuth), quên/đặt lại mật khẩu, đăng xuất, lưu phiên
F2 — Quản lý sản phẩm	CRUD sản phẩm, upload nhiều ảnh, gán tags, quản lý variants, soft delete / restore
F3 — Quản lý danh mục	CRUD danh mục đa cấp (tree), kéo thả sắp xếp, di chuyển danh mục cha
F4 — Giỏ hàng	Thêm/sửa/xóa sản phẩm, tính phí ship theo địa chỉ, áp dụng mã giảm giá, hỗ trợ guest
F5 — Thanh toán & Đặt hàng	Chọn địa chỉ giao hàng, đặt hàng, thanh toán COD / VNPay / SePay (QR), email xác nhận
F6 — Quản lý Profile	Xem/sửa thông tin cá nhân, đổi mật khẩu, upload avatar, CRUD địa chỉ giao hàng
F7 — Lịch sử mua hàng	Danh sách đơn hàng, lọc/tìm kiếm, xem chi tiết, hủy đơn, tra cứu đơn cho guest
F8 — Phân quyền (RBAC)	Quản lý Role và Permission, gán quyền cho role, gán role cho user, audit log
F9 — Quản lý người dùng	Danh sách tài khoản, xem chi tiết, khóa/mở khóa tài khoản, đổi mật khẩu thay user
F10 — Quản lý đơn hàng	Theo dõi đơn, cập nhật trạng thái (Pending→Processing→Shipped→Delivered), ghi chú nội bộ
F11 — Mã giảm giá	CRUD coupon (% hoặc VNĐ cố định), thiết lập điều kiện áp dụng, thời hạn, giới hạn lượt dùng
F12 — Kiểm duyệt nội dung	Duyệt/ẩn/xóa đánh giá sản phẩm, xử lý báo cáo vi phạm từ người dùng
F13 — Cấu hình hệ thống	Cài đặt chung (logo, tên site), SEO, liên hệ, mạng xã hội, banner, phí ship, SMTP, Google Auth
F14 — Thống kê & Báo cáo	Dashboard tổng quan, báo cáo doanh thu theo thời gian/danh mục/sản phẩm, xuất Excel
F15 — Live Chat hỗ trợ	Chat real-time giữa khách hàng và admin (SignalR), Admin xem/trả lời cuộc hội thoại, đánh dấu đã đọc
F16 — Testimonials	Hiển thị cảm nhận khách hàng trên trang chủ và trang riêng; Admin quản lý danh sách (bật/tắt hiển thị)
F17 — Điểm tích lũy	Tích điểm sau mỗi đơn hàng thành công, hiển thị điểm trên trang checkout và profile

2.2 Yêu cầu phi chức năng

Hiệu năng:

- Trang danh sách sản phẩm tải dưới 2 giây với dữ liệu thông thường
- API AJAX (lọc đơn hàng, cập nhật giỏ hàng) phản hồi dưới 1 giây

Khả năng mở rộng:

- Kiến trúc phân lớp (Controller → Service → Repository) cho phép mở rộng độc lập từng lớp
- Cấu hình phí ship và các thông số nghiệp vụ lưu trong DB, không hardcode

Độ ổn định:

- Lỗi gửi email không làm gián đoạn luồng đặt hàng (try-catch riêng biệt)
- Concurrency control khi nhiều admin cùng cập nhật đơn hàng

Khả năng sử dụng:

- Hỗ trợ AJAX cho các thao tác thường xuyên (lọc, cập nhật giỏ hàng, ghi chú)
- Thông báo lỗi rõ ràng, redirect hợp lý sau mỗi thao tác

2.3 Giả định và ràng buộc

- Hệ thống triển khai trên Windows Server với IIS
- Cơ sở dữ liệu SQL Server, kết nối qua Entity Framework Core
- Phí vận chuyển chia theo 3 vùng địa lý dựa trên danh sách quận/huyện cấu hình sẵn
- Google OAuth yêu cầu cấu hình Client ID/Secret từ Google Cloud Console
- VNPay và SePay yêu cầu tài khoản merchant riêng

---

3. Yêu cầu bảo mật

3.1 Quản lý quyền truy cập

Vai trò	Quyền truy cập
Guest	Public pages, giỏ hàng, đặt hàng, tra cứu đơn hàng bằng SĐT
Customer	Tất cả của Guest + profile, địa chỉ, lịch sử đơn, đánh giá sản phẩm
Admin	Khu vực Admin (F2–F14), không có quyền khóa tài khoản và quản lý RBAC
SuperAdmin	Toàn quyền Admin + khóa/mở khóa tài khoản + quản lý Role/Permission

- Phân quyền dựa trên RBAC (Role-Based Access Control) với attribute `[RequirePermission("module.action")]`
- Mọi action trong khu vực Admin yêu cầu xác thực `[Authorize(Roles = "Admin,SuperAdmin")]`
- Các thao tác nhạy cảm (khóa tài khoản, xóa vĩnh viễn) chỉ dành cho SuperAdmin

3.2 Bảo vệ dữ liệu

- Mật khẩu được hash trước khi lưu (không lưu plaintext)
- Token đặt lại mật khẩu có thời hạn, sử dụng một lần
- Anti-forgery token (`[ValidateAntiForgeryToken]`) trên tất cả form POST

- Chống Open Redirect: kiểm tra `Url.IsLocalUrl()` trước khi redirect theo `returnUrl`
- Input sanitization: địa chỉ giao hàng được encode HTML, lý do hủy đơn bị strip ký tự đặc biệt
- Mã SePay/VNPay không lưu thông tin thẻ trên server

---

4. Đặc tả Use Case

UC-01: Đăng ký tài khoản

Actor	Guest
Precondition	Chưa đăng nhập
Main Flow	1. Guest truy cập trang Đăng ký → 2. Nhập họ tên, email, mật khẩu, xác nhận mật khẩu → 3. Hệ thống kiểm tra email chưa tồn tại → 4. Tạo tài khoản, redirect sang trang Đăng nhập với thông báo thành công
Alternative Flow	Email đã tồn tại → hiển thị lỗi, giữ nguyên form
Postcondition	Tài khoản Customer được tạo trong hệ thống

UC-02: Đăng nhập

Actor	Customer, Admin, SuperAdmin
Precondition	Chưa đăng nhập
Main Flow	1. Nhập email + mật khẩu → 2. Tùy chọn "Remember Me" → 3. Hệ thống xác thực → 4. Tạo cookie → 5. Redirect: Admin/SuperAdmin → Admin Dashboard, Customer → trang chủ
Alternative Flow	Sai thông tin → hiển thị lỗi. Tài khoản bị khóa → hiển thị thông báo khóa
Postcondition	Cookie xác thực được thiết lập (24h hoặc 30 ngày nếu Remember Me)

UC-03: Đặt hàng

Actor	Guest, Customer
Precondition	Giỏ hàng có ít nhất 1 sản phẩm
Main Flow	1. Vào trang Checkout → 2. Chọn/nhập địa chỉ giao hàng → 3. Chọn phương thức thanh toán (COD/VNPay/SePay) → 4. Xác nhận đặt hàng → 5. Hệ thống kiểm tra tồn kho, tạo đơn hàng, xóa giỏ hàng → 6. Gửi email xác nhận → 7. Redirect trang xác nhận thành công
Alternative Flow	Hết hàng → thông báo lỗi, giữ nguyên trang checkout. VNPay thất bại → đơn hàng bị hủy, hiển thị trang thanh toán thất bại

Postcondition	Đơn hàng được tạo với trạng thái Pending

UC-04: Xử lý đơn hàng (Admin)

Actor	Admin, SuperAdmin
Precondition	Đã đăng nhập Admin, đơn hàng tồn tại
Main Flow	1. Xem danh sách đơn hàng → 2. Lọc theo trạng thái/ngày → 3. Vào chi tiết đơn → 4. Cập nhật trạng thái (Pending→Processing→Shipped→Delivered) → 5. Hệ thống kiểm tra tính hợp lệ của chuyển trạng thái → 6. Lưu lịch sử thay đổi
Alternative Flow	Chuyển trạng thái không hợp lệ → hiển thị lỗi. Xung đột đồng thời → yêu cầu tải lại trang
Postcondition	Trạng thái đơn hàng được cập nhật, lịch sử được ghi lại

UC-05: Áp dụng mã giảm giá

Actor	Guest, Customer
Precondition	Có sản phẩm trong giỏ hàng
Main Flow	1. Nhập mã giảm giá → 2. Hệ thống kiểm tra: mã tồn tại, còn hạn, chưa hết lượt dùng, đơn hàng đủ điều kiện (giá trị tối thiểu, số lượng tối thiểu) → 3. Áp dụng giảm giá, cập nhật tổng tiền
Alternative Flow	Không đủ điều kiện → hiển thị thông báo lý do cụ thể
Postcondition	Giỏ hàng hiển thị số tiền giảm và tổng mới

UC-06: Viết đánh giá sản phẩm

Actor	Customer
Precondition	Đã đăng nhập, đã mua và nhận sản phẩm (Verified Purchase)
Main Flow	1. Vào trang chi tiết sản phẩm → 2. Chọn số sao (1–5) + nhập nội dung → 3. Gửi đánh giá → 4. Đánh giá hiển thị trên trang sản phẩm
Alternative Flow	Chưa mua sản phẩm → nút đánh giá bị ẩn. Đã đánh giá rồi → chuyển sang chế độ chỉnh sửa
Postcondition	Đánh giá được lưu, thống kê rating sản phẩm được cập nhật

UC-07: Quản lý mã giảm giá (Admin)

Actor	Admin, SuperAdmin

Precondition	Đã đăng nhập Admin
Main Flow	1. Vào trang Coupon → 2. Tạo mới: nhập code, loại (% hoặc VNĐ), giá trị, điều kiện, ngày hiệu lực → 3. Lưu → 4. Coupon sẵn sàng cho khách hàng sử dụng
Alternative Flow	Code đã tồn tại → hiển thị lỗi trùng mã
Postcondition	Mã giảm giá được tạo và active trong hệ thống

UC-08: Xem báo cáo doanh thu (Admin)

Actor	Admin, SuperAdmin
Precondition	Đã đăng nhập Admin
Main Flow	1. Vào trang Thống kê → 2. Chọn khoảng thời gian (preset hoặc tùy chỉnh) → 3. Hệ thống hiển thị: tổng doanh thu, doanh thu theo danh mục, top sản phẩm, biểu đồ xu hướng → 4. Tùy chọn xuất Excel
Postcondition	Báo cáo hiển thị theo bộ lọc đã chọn; file Excel được tải về nếu yêu cầu

---

5. Yêu cầu khác

5.1 Giao diện người dùng (UI/UX)

- Giao diện responsive, tương thích desktop và mobile
- Khu vực Public sử dụng theme Fruitables (xanh lá `#81c408` làm màu chủ đạo)
- Khu vực Admin sử dụng Bootstrap 5 với sidebar điều hướng
- Thông báo thành công/lỗi hiển thị qua TempData (toast hoặc alert)
- Các thao tác thường xuyên (lọc, cập nhật giỏ hàng) sử dụng AJAX, không reload toàn trang

5.2 Đặc tả dữ liệu

Các entity chính:

Entity	Trường chính
User	Id, Name, Email, PasswordHash, Phone, Role, IsActive, LoyaltyPoints, GoogleId
Product	Id, Name, Slug, Description, Price, StockQuantity, CategoryId, IsDeleted
Order	Id, OrderNumber, UserId, Status, PaymentMethod, PaymentStatus, Total, ShippingFee
OrderItem	Id, OrderId, ProductId, Quantity, UnitPrice
Address	Id, UserId, FullName, Phone, ProvinceCode, CommuneName, StreetAddress, IsDefault
Coupon	Id, Code, Type, Value, MinOrderAmount, MinQuantity, MaxUses, UsedCount, StartDate, EndDate
Review	Id, UserId, ProductId, Rating, Comment, IsHidden, IsVerifiedPurchase

Entity	Trường chính
Role	Id, Name, Description, IsActive
Permission	Id, Name, Module, Description

Quy tắc dữ liệu:

- Slug sản phẩm/danh mục là duy nhất, chỉ chứa ký tự Latin, số và dấu gạch ngang
- Mật khẩu tối thiểu 6 ký tự
- Số điện thoại Việt Nam: 10–11 chữ số
- Ảnh sản phẩm lưu trên server, đường dẫn lưu trong DB

---

6. Tích hợp hệ thống

6.1 Cổng thanh toán

Dịch vụ	Phương thức	Mô tả
VNPay	Redirect	Chuyển hướng sang cổng VNPay, nhận kết quả qua callback URL
SePay	QR Code + Webhook	Hiển thị QR chuyển khoản, nhận xác nhận tự động qua webhook POST

6.2 Xác thực bên thứ ba

Dịch vụ	Phương thức	Mô tả
Google OAuth 2.0	Redirect flow	Đăng nhập bằng tài khoản Google, có thể bật/tắt từ Admin Settings

6.3 Dịch vụ email

Dịch vụ	Phương thức	Mô tả
SMTP	SmtpClient	Gửi email xác nhận đơn hàng, mật khẩu tạm thời. Cấu hình host/port/SSL từ Admin Settings

6.4 Tiêu chuẩn giao tiếp

- Nội bộ: RESTful JSON API cho các AJAX endpoint
- Thanh toán: HTTPS redirect + webhook (JSON body)
- Real-time: SignalR WebSocket cho Live Chat